



MSc Cyber Security Engineering

Proactive Cyber Defence

Incident Analysis Report

Submitted By:
Madhuchandra Sethunath

I hereby declare that this assessment is my own work and that all sources have been acknowledged.

2025-26

Table of Contents

1	<i>Executive summary</i>	4
1.1	Executive summary (for stakeholders)	4
1.2	Analysis summary (for SOC / incident responders)	4
1.3	Impacted assets and identities	4
1.4	TTPs and IOCs (summary)	4
1.5	Case overview and background	5
1.6	Key findings	5
1.7	Recommendations to improve security posture	6
2	<i>Analysis of Logs</i>	6
2.1	Executable uploaded by PoisonIvy	6
2.2	Brute Force Password Samples	8
2.3	Total Unique Passwords in Brute Force Attempt	10
2.4	Ransomware File Server Target	11
2.5	PDF File Encryption on Remote Server	12
2.6	Text File Encryption on Bob Smith's Workstation	14
2.7	VBScript ParentProcessId and Temp File	15
3	<i>Detection Rules</i>	16
3.1	Rule 1: Detecting Malicious File Uploads.....	16
3.2	Rule 2: Identifying Brute Force Attacks.....	17
3.3	Rule 3: Detecting Ransomware Network Activity.....	19
3.4	Rule 4: Identifying File Encryption Behaviour.....	20
3.5	Rule 5: Detecting Malicious Script Execution	22
4	<i>Mitre Attack Analysis</i>	24
4.1	Attack Chain Reconstruction	24
4.2	MITRE ATT&CK Tactic Mapping	25
4.2.1	Initial Access (TA0001).....	25
4.2.2	Execution (TA0002)	26
4.2.3	Defense Evasion (TA0005)	26
4.2.4	Credential Access (TA0006)	26
4.2.5	Lateral Movement (TA0008).....	27
4.2.6	Command and Control (TA0011)	27
4.2.7	Impact (TA0040)	27
4.3	Technique Summary Mapping	28

4.4	MITRE D3FEND Defensive Architecture	29
4.5	Threat Actor Attribution.....	30
4.6	Security Posture Gap Analysis.....	30
5	<i>References</i>	30
6	<i>Appendices</i>	32
	A1. MITRE ATT&CK Heatmap	32
	A2. Windows and Sysmon Event IDs.....	33

1 Executive summary

1.1 Executive summary (for stakeholders)

Wayne Enterprises experienced two related compromises: a brute-force takeover of the public Joomla site www.imreallynotbatman.com and a ransomware (potentially Cerber) outbreak originating from workstation we8105desk and propagating to file server we9041srv. In both incidents, weak authentication, unrestricted USB and macro usage, and lack of network segmentation allowed an external adversary to move from user-driven initial access to large-scale data encryption, exposing major defence-in-depth and monitoring gaps.

1.2 Analysis summary (for SOC / incident responders)

SIEM, web-server and Sysmon telemetry were correlated to reconstruct the end-to-end kill chain for each scenario. For the website compromise, HTTP logs showed 412 unique password attempts against /administrator/ from 23.22.63.114, followed by an authenticated upload of 3791.exe from 40.80.148.42, mapped to ATT&CK T1110.001 and T1105 (MITRE, 2024). For the ransomware incident, Windows and Sysmon logs traced macro-driven VBScript execution (Miranda_Tate_unveiled.dotm → 20429.vbs → 121214.tmp), 52,270 SMB connections from we8105desk to 192.168.250.100, and encryption of 257 PDFs on the server and 406 text files locally, mapped to T1204.002, T1059.005, T1021.002 and T1486. A single MITRE ATT&CK heatmap (Appendix A1) and MITRE D3FEND control mapping were then used to derive focused detection rules and hardening measures.

1.3 Impacted assets and identities

Incident	Asset / Identity	Details
Website compromise (A)	Web server - 192.168.250.70	Hosts www.imreallynotbatman.com Joomla site.
Website compromise (A)	Joomla administrator account	Target of brute force from 23.22.63.114.
Ransomware (B)	Workstation we8105desk	Bob Smith's Windows 10 desktop.
Ransomware (B)	User WAYNECORPINC\bob.smith	Initial infected user account.
Ransomware (B)	File server we9041srv - 192.168.250.100	Encrypted at least 257 PDFs on shared volumes.
Ransomware (B)	Local user profile files	406 text files encrypted in Bob's profile.

1.4 TTPs and IOCs (summary)

Type	ID / Indicator	Description / Where observed
TTP	T1566.001	Malicious .dotm on USB (Miranda_Tate_unveiled.dotm).
TTP	T1204.002	User opens malicious document on we8105desk.
TTP	T1059.005	wscript.exe runs 20429.vbs - > 121214.tmp.
TTP	T1027	Payload stored as .tmp in user profile.
TTP	T1110.001	412 unique password attempts to /administrator/.
TTP	T1105	Upload of 3791.exe via HTTP POST.
TTP	T1021.002	52,270 SMB connections to 192.168.250.100.
TTP	T1486	Encryption of 257 PDFs (server) and 406 TXTs (local).
IOC	23.22.63.114	Brute-force source IP.
IOC	40.80.148.42	Executable upload source IP.
IOC	192.168.250.70 / 192.168.250.100	Web server and file server IPs.
IOC	3791.exe, 20429.vbs, 121214.tmp	Malicious binaries and scripts.
IOC	# DECRYPT MY FILES # notes, .cerber	Cerber ransomware artefacts.

1.5 Case overview and background

SOC Tier 3 identified historical anomalies suggesting a previously undetected compromise and extracted relevant logs for post-incident review. Investigation of external reports that imreallynotbatman.com had been defaced led to focused analysis of web traffic to 192.168.250.70, revealing brute-force activity and executable upload to the Joomla instance. In parallel, a long-standing critical ticket describing Bob Smith's workstation suddenly playing audio, changing wallpaper and losing file access was revisited as a likely ransomware event, and endpoint plus file-server logs were ingested into the SIEM for correlation.

1.6 Key findings

- Joomla admin interface was exposed to the internet without effective lockout, CAPTCHA or MFA, enabling a successful brute-force attack from 23.22.63.114.
- Attacker infrastructure at 40.80.148.42 uploaded 3791.exe via HTTP POST after credential compromise (MITRE, 2024; OWASP, 2021), providing a post-exploitation tool on the web server.
- Bob Smith's execution of Miranda_Tate_unveiled.dotm from removable media initiated a macro-driven VBScript and temporary payload chain that AV and EDR did not stop, likely due to legacy exclusions on user-profile locations.
- Ransomware from we8105desk generated a large spike in SMB traffic to we9041srv and encrypted at least 257 PDF files on the server and 406 text files on the local profile, consistent with Cerber behaviour (Kaspersky Lab, 2016; Cisco Talos, 2016).

- Lack of network segmentation, least-privilege controls and behaviour-based detection allowed a single compromised user to lead to full file-server impact without effective containment.

1.7 Recommendations to improve security posture

- Enforce multi-factor authentication, strong password policies, CAPTCHA and logout thresholds on all internet-facing administrative interfaces such as Joomla.
- Disable or tightly control USB storage and Office macros for standard users, and introduce sandboxing and content inspection for macro-enabled documents.
- Implement network segmentation and access controls so workstations cannot directly reach file-server SMB shares, requiring monitored jump hosts or gateways.
- Deploy EDR and SIEM detections for high-rate authentication attempts, abnormal SMB connection spikes, mass file-modification bursts and script interpreters spawning executables from user-writable paths.
- Maintain regular, tested backups for critical file shares and use decoy files or honeypot shares to trigger rapid isolation when ransomware-like encryption is detected.

2 Analysis of Logs

2.1 Executable uploaded by PoisonIvy

a. Investigation

To identify the compromised web server, HTTP traffic for imreallynotbatman.com was aggregated by destination IP, which highlighted 192.168.250.70 as the main host serving the site.

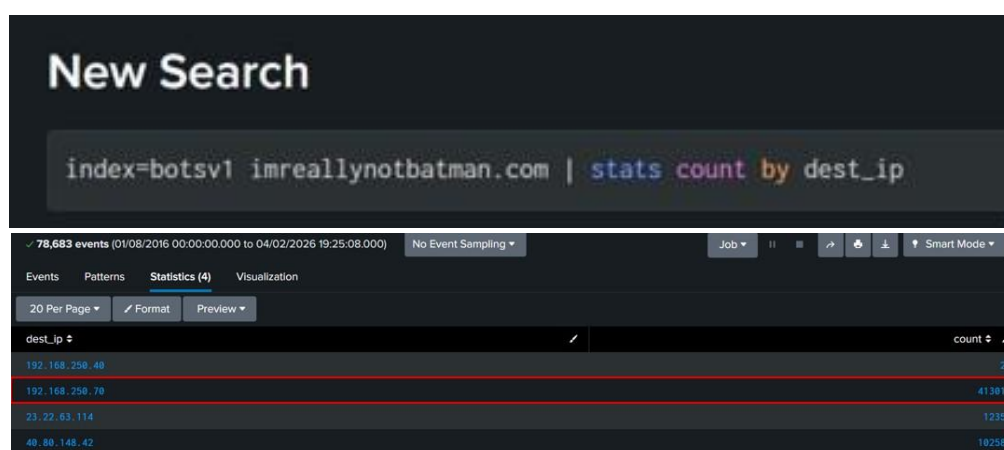


Figure 2.1.1 -- 192.168.250.70 identified as the web server

Web-server logs were then filtered for requests containing .exe in the URI to locate uploaded executables.

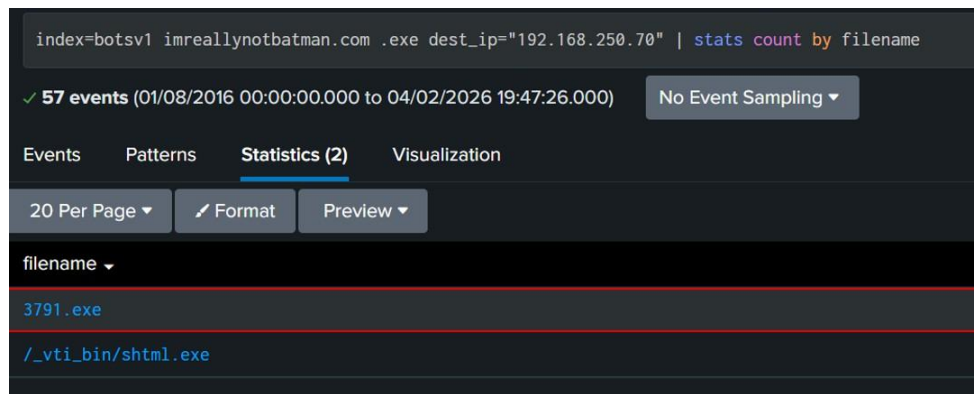


Figure 2.1.2 - Two .exe entries identified; 3791.exe confirmed as uploaded.

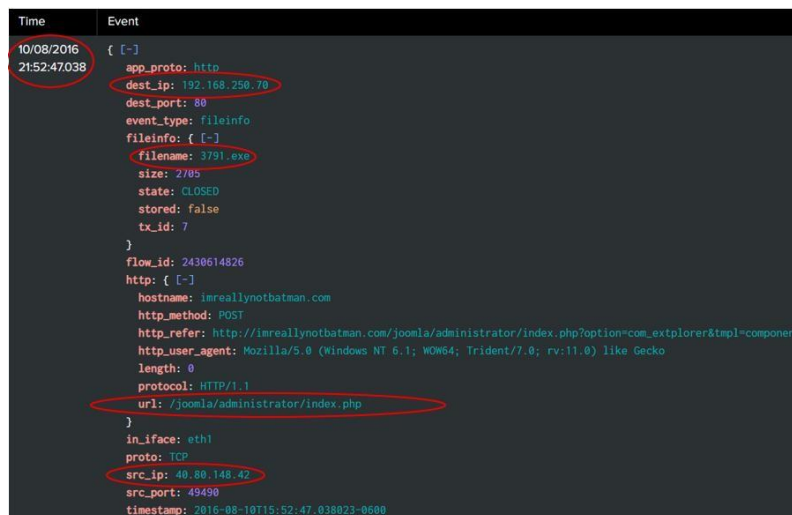


Figure 2.1.3 - Detailed event view of 3791.exe

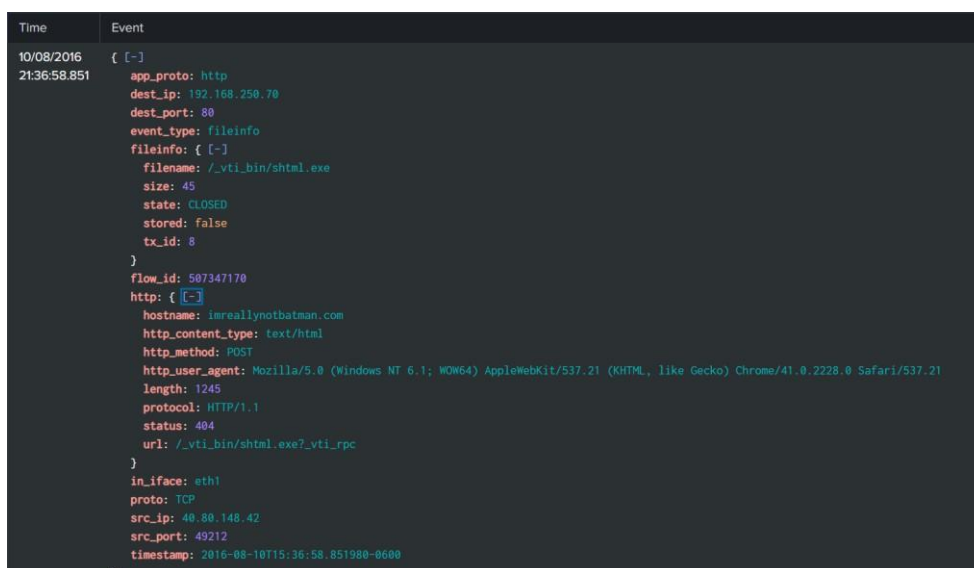


Figure 2.1.4 - Detailed event view of shtml.exe

b. Analysis

Two .exe entries were identified in the web-server logs. The path /vti_bin/shtml.exe corresponded to Acunetix scanning activity (404 status) and was excluded as benign. The remaining upload, 3791.exe, occurred via the Joomla administrative interface and maps to MITRE ATT&CK T1105 (Ingress Tool Transfer) (MITRE, 2024), indicating post-compromise deployment of a tool using valid admin credentials.

c. Findings

- Confirmed compromised web server: 192.168.250.70 hosting imreallynotbatman.com.
- Malicious executable uploaded: 3791.exe on 10 August 2016 at 21:52:47.
- Upload path: Joomla administrator interface from external IP 40.80.148.42.
- Technique: T1105 - Ingress Tool Transfer.

2.2 Brute Force Password Samples

a. Investigation

HTTP logs were filtered for POST requests to /administrator/ on 192.168.250.70 to isolate Joomla login attempts. This revealed two external IPs, with 23.22.63.114 responsible for 412 requests in a short window.

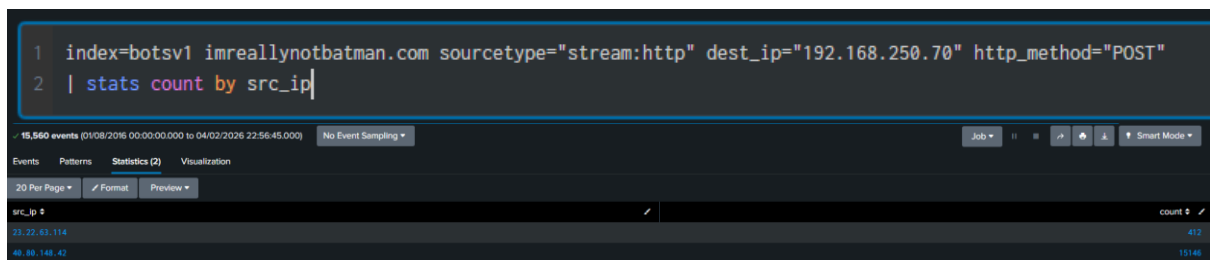


Figure 2.2.1 - Two IPs identified - 40.80.148.42 (15,146 requests) and 23.22.63.114 (412 requests).

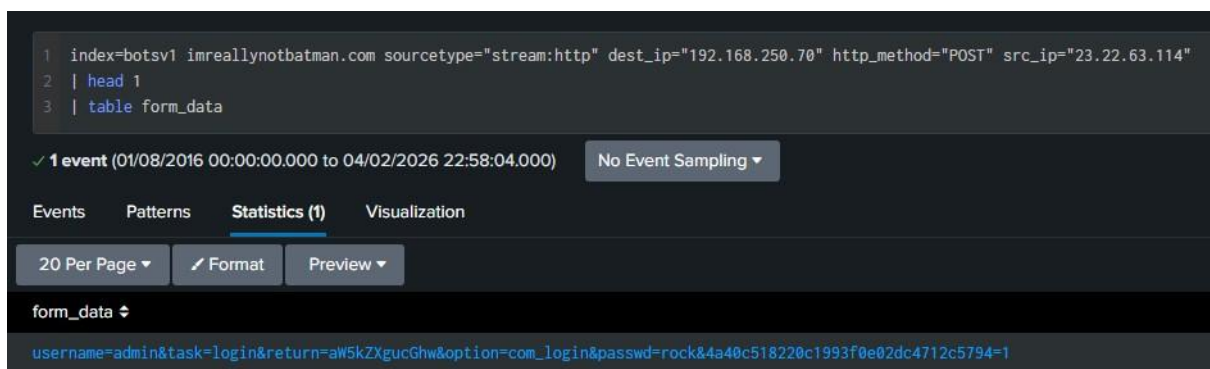


Figure 2.2.2 - Form data revealed authentication parameters "username" and "passwd".

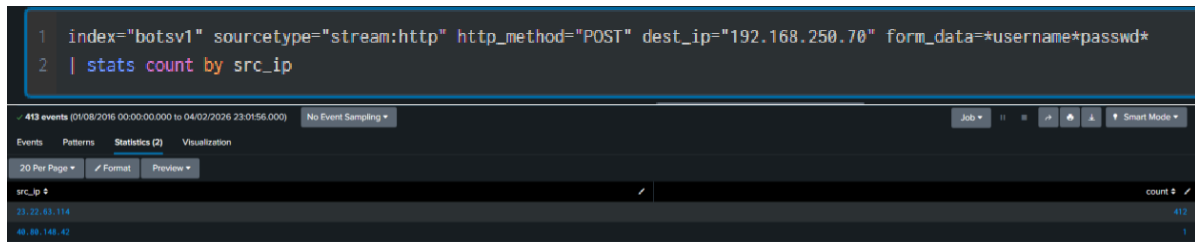


Figure 2.2.3 - IP 23.22.63.114 identified with 412 authentication attempts.

A regex extraction of the password field was applied to the 23.22.63.114 events to pull candidate passwords into a separate field for review and sampling.

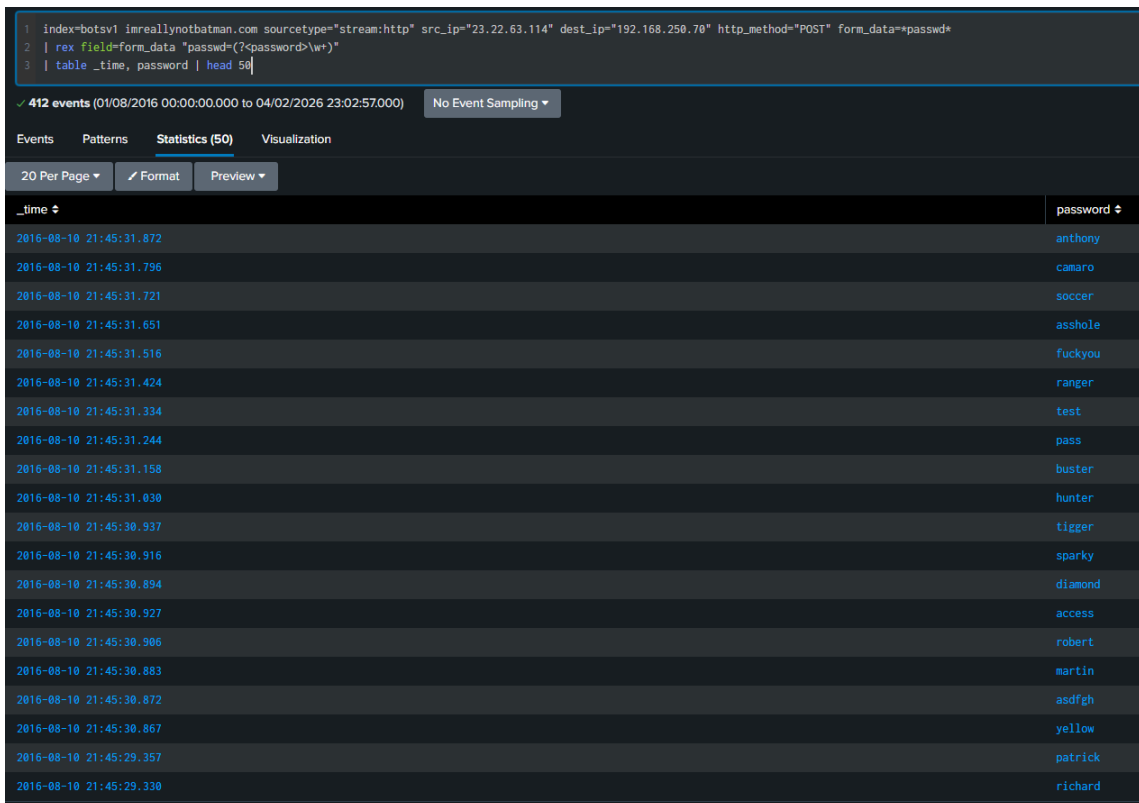


Figure 2.2.4 - Multiple passwords extracted including yellow, camaro, soccer, anthony.

Temporal sorting was applied to identify the first password attempted.



Figure 2.2.5 - First password identified as "hotdog".

b. Analysis

All 412 authentication attempts from 23.22.63.114 occurred within roughly one minute, with millisecond-spaced HTTP POST requests, demonstrating automated guessing rather than manual login failures. The extracted passwords (for example “hotdog”, “yellow”, “camaro”, “soccer”) are common dictionary words, consistent with a wordlist attack tool. This behaviour aligns with MITRE ATT&CK T1110.001 (Brute Force: Password Guessing) against the Joomla administrator account (MITRE, 2024).

c. Findings

- Sample passwords observed: “hotdog” (first), “yellow”, “camaro”, “soccer”.
- Brute-force source: 23.22.63.114 targeting `imreallynotbatman.com /administrator/`.
- Total authentication attempts: 412 within ~60 seconds.
- Technique: T1110.001 - Brute Force: Password Guessing.

2.3 Total Unique Passwords in Brute Force Attempt

a. Investigation

The same extracted password field from 23.22.63.114 was used to calculate a distinct count, grouping by password value.

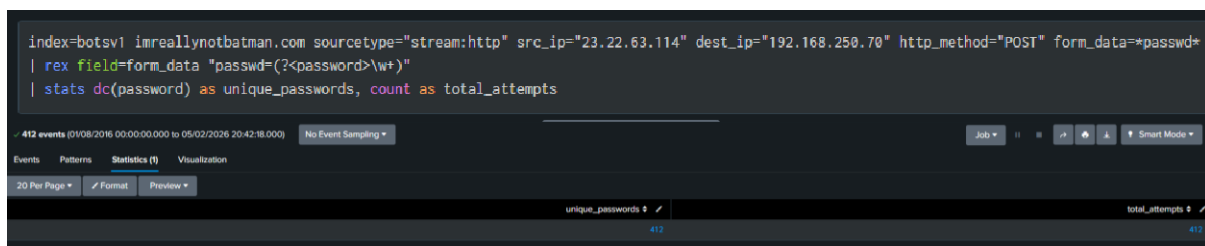


Figure 2.3.1 - Distinct count of unique passwords extracted from brute force attempts.

b. Analysis

Distinct-count analysis of the POST parameters showed that all 412 submitted password values were unique, with no reuse. This confirms a linear dictionary-based brute-force attack where each candidate from a wordlist is tried once against the same administrative account. Such behaviour is typical of automated credential-guessing tools rather than targeted manual attempts.

c. Findings

- Total authentication attempts: 412.
- Total unique passwords: 412 (one-to-one ratio with attempts).
- Attack pattern: sequential dictionary attack against Joomla admin.
- Technique: T1110.001 - Brute Force: Password Guessing.

2.4 Ransomware File Server Target

a. Investigation

Sysmon EventCode 3 (Network Connection) logs from we8105desk on 24 August 2016 were filtered for SMB ports 445 and 139 to identify file-server traffic during the suspected ransomware window.

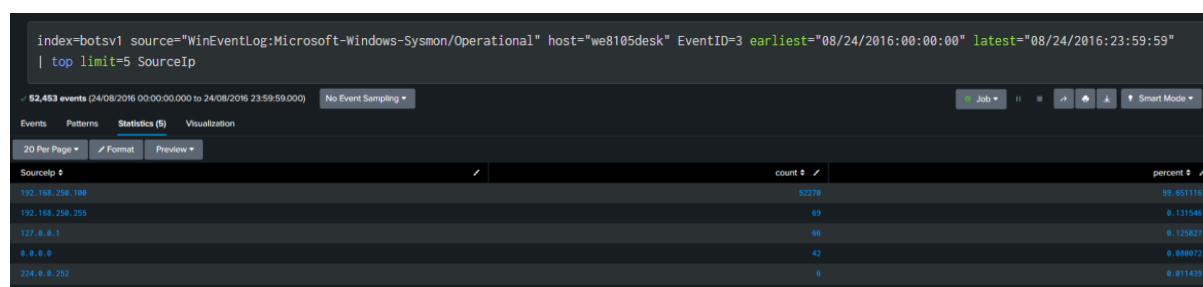


Figure 2.4.1 - Sysmon network connections from we8105desk showing 192.168.250.100 as the dominant SMB destination.

Connection counts were aggregated by destination IP, which showed 192.168.250.100 with 52,270 connections, far exceeding any other host.

Type	Field	Value	Actions
Selected	DestinationHostname	we9041srv	
	SourceIp	192.168.250.100	
	host	we8105desk	
	source	WinEventLog:Microsoft-Windows-Sysmon/Operational	
	sourcetype	XmlWinEventLog:Microsoft-Windows-Sysmon/Operational	

Figure 2.4.2 - Network connection showing DestinationHostname we9041srv with SourceIp 192.168.250.100.

b. Analysis

Sysmon EventCode 3 logs on 24 August 2016 showed 52,270 SMB connections from we8105desk to 192.168.250.100, far exceeding connections to any other destination. The destination hostname resolved to we9041srv, Wayne Enterprises' file server. This high-volume SMB activity during the ransomware window is consistent with encryption workflows iterating over many shared files and maps to T1021.002 (Remote Services: SMB/Windows Admin Shares) and T1486 (Data Encrypted for Impact) (MITRE, 2024).

c. Findings

- Target file server: we9041srv - 192.168.250.100.
- Source host: we8105desk (WAYNECORPINC\bob.smith).
- SMB connections observed: 52,270 during attack period.

- Techniques: T1021.002 - Remote Services: SMB/Windows Admin Shares; T1486 - Data Encrypted for Impact.

2.5 PDF File Encryption on Remote Server

a. Investigation

Windows Security Event ID 5145 on we9041srv was queried for events generated by WAYNECORPINC\bob.smith around the ransomware timeframe to identify file-share activity.

The screenshot shows a Splunk search interface with the query: `index=botsv1 host=we9041srv sourcetype="WinEventLog:Security" EventCode=5145 | stats count by Relative_Target_Name`. The results table lists various file paths and their access counts.

Relative_Target_Name	count
# DECRYPT MY FILES #.html	4
# DECRYPT MY FILES #.txt	2
# DECRYPT MY FILES #.url	3
# DECRYPT MY FILES #.vbs	2
Extend\Quota\0\INDEX_ALLOCATION	2
000	133
000\# DECRYPT MY FILES #.html	5
000\# DECRYPT MY FILES #.txt	5
000\# DECRYPT MY FILES #.url	5
000\# DECRYPT MY FILES #.vbs	5
000\000576.pdf	3
000\000816.pdf	4
000\4TP0A1B07.corber	2
000\2y1r1ueg2T.corber	1
000\desktop.ini	1
001	127
001\# DECRYPT MY FILES #.html	6
001\# DECRYPT MY FILES #.txt	6
001\# DECRYPT MY FILES #.url	6
001\# DECRYPT MY FILES #.vbs	6

Figure 2.5.1 - File access logs showing ransom note creation ("# DECRYPT MY FILES #" in multiple formats).

Events where the RelativeTargetName ended with .pdf were isolated to focus on PDF operations, and the access types were summarised to identify READ_CONTROL and DELETE patterns.

The screenshot shows a Splunk search interface with the query: `index=botsv1 host=we9041srv sourcetype="WinEventLog:Security" EventCode=5145 Relative_Target_Name=*.pdf | stats count by Accesses`. The results table shows the count of operations for different access types.

Accesses	count
DELETE	267
READ_CONTROL	257
ReadAttributes	11

Figure 2.5.2 - PDF file operations showing DELETE (267), READ_CONTROL (257), and ReadAttributes (1).

A distinct count over the .pdf filenames with DELETE operations was used to determine the number of unique PDF originals removed after encryption.

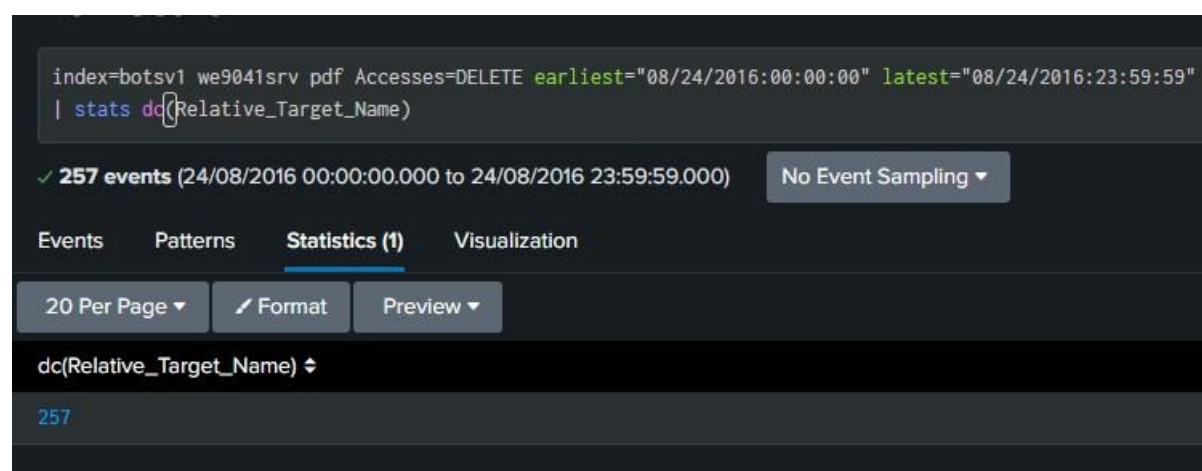


Figure 2.5.3 - Query result confirming 257 unique PDF files deleted.

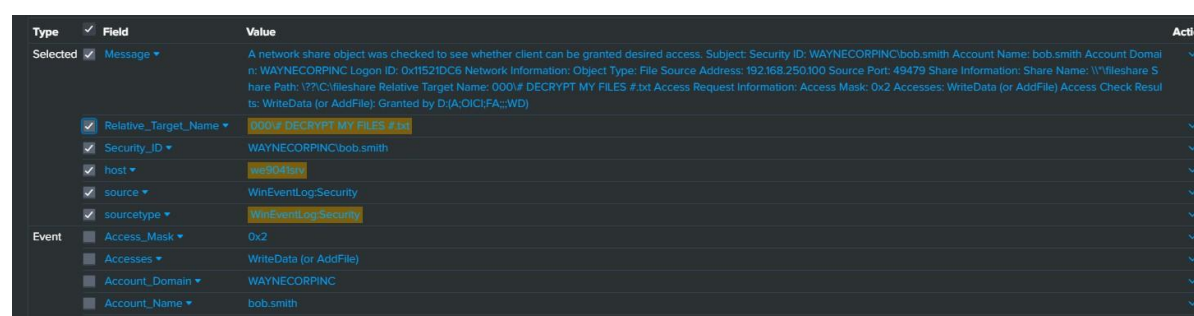


Figure 2.5.4 - Event detail showing ransom note (000\# DECRYPT MY FILES #.txt) created by bob.smith account with WriteData access.

b. Analysis

Windows Event ID 5145 on we9041srv recorded the creation of multiple “# DECRYPT MY FILES #” ransom notes across file types and extensive operations on .pdf files by WAYNECORPINC\bob.smith. The activity is consistent with Cerber ransomware based on the characteristic ransom note naming and the presence of .cerber files observed in the file access logs. PDF-specific events showed 267 DELETE operations and READ_CONTROL on 257 distinct files, matching the pattern of read original, write encrypted copy, then delete the source. The distinct count of 257 therefore represents the number of unique PDF files encrypted by the ransomware (Scaife et al., 2016; Kharraz et al., 2015).

c. Findings

- Unique PDF files encrypted (originals deleted): 257.
- Host: file server we9041srv - 192.168.250.100.
- Ransomware artefacts: multiple “# DECRYPT MY FILES #” notes in .txt, .html, .url, .vbs.
- Technique: T1486 - Data Encrypted for Impact.

- Unique text files encrypted (creation time changed): 406.
- Affected host: we8105desk (Bob Smith's workstation).
- Location: C:\Users\bob.smith.WAYNECORPINC\ profile.
- Technique: T1486 - Data Encrypted for Impact.

2.7 VBScript ParentProcessId and Temp File

a. Investigation

Sysmon EventCode 1 (Process Create) logs from 24 August 2016 were searched for wscript.exe and cscript.exe processes running under Bob Smith's user context to identify script execution linked to the ransomware.

```

index=botsv1 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 (Image="wscript.exe" OR Image="cscript.exe") earliest="08/24/2016:00:00:00" latest="08/24/2016:23:59:59"
| table _time CommandLine ProcessId ParentProcessId ParentImage
| sort _time
  
```

_time	CommandLine	ProcessId	ParentProcessId	ParentImage
2016-08-24 16:48:21	cscript.exe /nologo C:\Windows\TEMP\3548D0D-70D0-4893-941234567890.vbs	3968	3884	C:\Program Files (x86)\Common-Files\Acronis\Infrastructure\wmi.exe
2016-08-24 16:48:21	cscript.exe /nologo C:\Windows\TEMP\3548D0D-70D0-4893-941234567890.vbs	3968	3884	C:\Program Files (x86)\Common-Files\Acronis\Infrastructure\wmi.exe
2016-08-24 16:48:21	cscript.exe /nologo C:\Windows\TEMP\3548D0D-70D0-4893-941234567890.vbs	3968	3884	C:\Program Files (x86)\Common-Files\Acronis\Infrastructure\wmi.exe
2016-08-24 16:48:21	"C:\Windows\System32\cmd.exe" "C:\Users\Bob.Smith.WAYNECORPINC\AppData\Roaming\20429.vbs"	3968	3884	C:\Windows\System32\cmd.exe
2016-08-24 17:15:12	"C:\Windows\System32\cmd.exe" "C:\Users\Bob.Smith.WAYNECORPINC\AppData\Roaming\121214.tmp"	1476	3968	C:\Users\Bob.Smith.WAYNECORPINC\AppData\Roaming\121214.tmp

Figure 2.7.1 - Windows Script Host (wscript.exe) executing VBScript 20429.vbs, showing ProcessId 3968 and ParentProcessId 3884 (cmd.exe).

Child processes of wscript.exe PID 3968 were then inspected, revealing a subsequent process with an image path ending in 121214.tmp.

```

index=botsv1 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 ParentProcessId=3968 earliest="08/24/2016:00:00:00" latest="08/24/2016:23:59:59"
| table _time Image CommandLine ProcessId ParentProcessId
| sort _time
  
```

_time	Image	CommandLine	ProcessId	ParentProcessId
2016-08-24 16:48:21	C:\Windows\System32\cmd.exe	"C:\Windows\System32\cmd.exe" /C START "" "C:\Users\Bob.Smith.WAYNECORPINC\AppData\Roaming\121214.tmp"	1476	3968

Figure 2.7.2 - Child process 121214.tmp launched with ParentProcessId 3968 (wscript.exe).

The full path to 20429.vbs in AppData\Roaming and the .tmp payload in Bob Smith's profile were documented to support the macro-delivered VBScript execution chain.

b. Analysis

Sysmon EventCode 1 (Process Create) logs show wscript.exe (PID 3968), invoked by cmd.exe (PID 3884), executing C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\20429.vbs. A child process 121214.tmp was then launched with parent PID 3968, indicating the VBScript dropped and executed a temporary payload in the user profile. This chain (cmd.exe -> wscript.exe -> 20429.vbs -> 121214.tmp) is typical of macro-delivered ransomware and

maps to T1059.005 (Visual Basic) and T1027 (obfuscated/hidden payload via .tmp) (MITRE, 2024; Microsoft, 2021).

c. Findings

- ParentProcessId of temp file launch: 3968 (wscript.exe)
- Temp file name executed by VBScript: 121214.tmp
- VBScript file: 20429.vbs in Bob Smith's roaming profile.
- Techniques: T1059.005 - Command and Scripting Interpreter: Visual Basic; T1027 - Obfuscated Files or Information.

3 Detection Rules

3.1 Rule 1: Detecting Malicious File Uploads

```
title: Malicious Executable Upload Detection
id: 3ac7a7c3-92b1-4820-b905-4ebe3227e7cb
status: stable
description: >
  Detects upload of executable files to web servers via HTTP POST,
  indicating potential post-exploitation tool transfer (T1105).
author: Madhuchandra Sethunath
date: 2026/02/06
modified: 2026/02/06
references:
  - https://attack.mitre.org/techniques/T1105/

logsource:
  category: proxy
  product: web

detection:
  selection_method:
    cs-method: 'POST'

  selection_extensions:
    cs-uri-stem|endswith:
      - '.exe'
      - '.dll'
      - '.bat'
      - '.ps1'
      - '.vbs'

  selection_success:
    sc-status: 200
```



```

filter_internal_admin:
  c-ip|cidr:
    - '192.168.0.0/16'
    - '10.0.0.0/8'
  cs-uri-stem|contains: '/admin/'

filter_legitimate_updates:
  cs-uri-stem|contains:
    - '/updates/'
    - '/patches/'
  cs-referer|contains: 'trusted-domain.com'

condition: all of selection_* and not filter_internal_admin and not
filter_legitimate_updates

falsepositives:
  - Authorized CMS updates
  - Legitimate software deployment

level: high

tags:
  - attack.command_and_control
  - attack.t1105

fields:
  - c-ip
  - cs-uri-stem
  - cs-method
  - sc-status

notes: |
  Severity: HIGH - Post-exploitation indicator requiring immediate
  investigation.
  Expected volume: <5 alerts/month in 1000-user environment.

```

3.2 Rule 2: Identifying Brute Force Attacks

```

title: HTTP Brute Force Attack Detection
id: 1f812383-ebb1-411b-9010-b613bf619b75
status: stable
description: >
  Detects rapid sequential HTTP authentication attempts, indicative of
  credential stuffing or brute force (T1110.001).
author: Madhuchandra Sethunath

```

```
date: 2026/02/06
modified: 2026/02/06
references:
  - https://attack.mitre.org/techniques/T1110/001/

logsource:
  category: webserver
  product: web

detection:
  selection_auth:
    cs-method: 'POST'
    cs-uri-stem|contains:
      - '/administrator/'
      - '/wp-admin/'
      - '/login'
      - '/auth'
    cs-post-body|contains:
      - 'username'
      - 'password'

  timeframe: 5m
  condition: selection_auth | count(cs-method) by c-ip > 10

falsepositives:
  - Legitimate users mistyping passwords
  - Password manager auto-fill failures
  - Internal authentication testing tools

level: high

tags:
  - attack.credential_access
  - attack.t1110.001

fields:
  - c-ip
  - cs-uri-stem
  - cs-method

notes: |
  Threshold aggregation may require SIEM-specific syntax adjustment.
  Splunk: stats count by c-ip | where count > 10
  Elastic: use native threshold rule type
  Severity: HIGH - Credential access attempt requiring immediate blocking.
  Expected volume: <10 alerts/month in 1000-user environment.
```

3.3 Rule 3: Detecting Ransomware Network Activity

```
title: Ransomware SMB Traffic Spike
id: 7ffe980f-738c-46dc-83b2-e714fd3bfa6d
status: experimental

related:
  - id: f9b3a99d-3c75-4766-9e50-d46b20a26af4
    type: similar

description: >
  Detects unusually high SMB connection volume from a single host, consistent
  with ransomware behaviour (T1486/T1021.002).
author: Madhuchandra Sethunath
date: 2026/02/06
modified: 2026/02/06

references:
  - https://attack.mitre.org/techniques/T1021/002/
  - https://attack.mitre.org/techniques/T1486/

logsource:
  product: windows
  service: sysmon
  definition: Sysmon EventID 3 with network logging enabled

detection:
  selection:
    EventID: 3
    DestinationPort:
      - 445
      - 139
    Initiated: 'true'
    SourcePort: '>1024'

  filter_servers:
    SourceHostname|endswith:
      - 'srv'
      - 'backup'
      - 'nas'

  timeframe: 10m
  condition: selection and not filter_servers | count(EventID) by SourceIp,
  DestinationIp > 200
```

```

falsepositives:
  - Scheduled backups
  - Antivirus scans
  - Bulk file copy operations

level: critical

tags:
  - attack.lateral_movement
  - attack.t1021.002
  - attack.impact
  - attack.t1486

fields:
  - SourceIp
  - DestinationIp
  - EventID
  - SourceHostname

notes: |
  Time-based suppression (backup windows) should be configured in SIEM
  scheduling.
  Threshold set at 200 connections per 10 minutes (conservative baseline).
  Consider tightening to >500 after 2-week baseline validation.
  Severity: CRITICAL - Ransomware activity requiring immediate isolation.

```

3.4 Rule 4: Identifying File Encryption Behaviour

```

title: Ransomware File Encryption Behavior
id: aa75d18c-1621-4c1f-80b0-75e3fe3cfca0
status: stable

related:
  - id: 2c76a22b-702d-48fd-8fa9-e41e2fe203b3
    type: similar

description: >
  Detects rapid modification of large volumes of files, a behavioural
  signature
  of ransomware encryption (T1486).
author: Madhuchandra Sethunath
date: 2026/02/06
modified: 2026/02/06

references:

```

- <https://attack.mitre.org/techniques/T1486/>

logsource:

product: windows
service: sysmon
definition: Sysmon EventID 2 file creation time monitoring

detection:

selection:
EventID: 2

selection_ransomware_extensions:

TargetFilename|endswith:

- '.encrypted'
- '.locked'
- '.crypto'
- '.cerber'
- '.locky'
- '.zepto'

filter_system_processes:

Image|endswith:

- '\Windows\System32\msiexec.exe'
- '\Windows\System32\svchost.exe'
- '\Windows\explorer.exe'
- '\Windows\System32\SearchIndexer.exe'

filter_system_directories:

TargetFilename|startswith:

- 'C:\Windows\'
- 'C:\Program Files\'
- 'C:\Program Files (x86)\'

filter_extensions:

TargetFilename|endswith:

- '.tmp'
- '.log'
- '.etl'

timeframe: 1m

condition: (selection or selection_ransomware_extensions) and not any of
filter_* | count(TargetFilename) by Image > 100

falsepositives:

- File compression utilities
- Software installation extracting packages

- Development build processes

level: critical

tags:

- attack.impact
- attack.t1486
- ransomware.generic

fields:

- Image
- TargetFilename
- EventID

notes: |

Consolidated threshold logic to trigger on:

- Generic high-volume file changes (>100 files/min), OR
- ANY ransomware-specific extension changes (regardless of volume)

Severity: CRITICAL - Active ransomware encryption requiring immediate containment.

Expected detection latency: <30 seconds.

3.5 Rule 5: Detecting Malicious Script Execution

title: VBScript Launching Temp Executable

id: c19439ca-915a-46a3-9c81-6992e3e94e81

status: stable

related:

- id: cea72823-df4d-4567-950c-0b579eaf0846
type: similar
- id: 1f49f2ab-26bc-48b3-96cc-dcffbc93eadf
type: similar

description: >

Detects wscript/cscript or PowerShell spawning executables from temporary locations, common in macro-based phishing (T1059.005/T1027).

author: Madhuchandra Sethunath

date: 2026/02/06

modified: 2026/02/06

references:

- <https://attack.mitre.org/techniques/T1059/005/>
- <https://attack.mitre.org/techniques/T1027/>

```

logsource:
  product: windows
  service: sysmon
  definition: Sysmon EventID 1 with command line logging

detection:
  selection_parent:
    EventID: 1
    ParentImage|endswith:
      - '\wscript.exe'
      - '\cscript.exe'
      - '\powershell.exe'
      - '\pwsh.exe'

  selection_suspicious_path:
    Image|contains:
      - '\AppData\Local\Temp\'
      - '\AppData\Roaming\'
      - '\Users\Public\'
      - '\ProgramData\'

  selection_suspicious_extension:
    Image|endswith:
      - '.tmp'
      - '.tmp.exe'

  selection_parent_powershell_evasion:
    ParentCommandLine|contains:
      - '-ExecutionPolicy Bypass'
      - '-enc '
      - 'hidden'
      - '-NonInteractive'
      - '-NoProfile'

  filter_legitimate_scripts:
    ParentCommandLine|contains:
      - 'C:\Windows\System32\'
      - 'C:\Program Files\'
    User|contains: 'SYSTEM'

  filter_signed:
    ImageSigned: 'true'
    ImageSignatureVerified: 'true'

condition: >
  selection_parent and

```

```
(selection_suspicious_path or  
selection_suspicious_extension or  
selection_parent_powershell_evasion) and  
not any of filter_*
```

falsepositives:

- Enterprise VBScript installers
- Admin automation scripts via GPO/SCCM
- Legitimate PowerShell deployment tools

level: high

tags:

- attack.execution
- attack.t1059.005
- attack.defense_evasion
- attack.t1027

fields:

- Image
- ParentImage
- CommandLine
- ParentCommandLine

notes: |

Includes PowerShell variant detection and evasion indicators.

Optional SIEM-side hash whitelisting recommended for legitimate installers.

Severity: HIGH - Likely macro-based malware requiring investigation.

Expected volume: <15 alerts/month in 1000-user environment.

4 Mitre Attack Analysis

This analysis maps the attack chain to MITRE ATT&CK and identifies defensive countermeasures using MITRE D3FEND. The consolidated technique coverage and scoring are visualised in Appendix A1 - MITRE ATT&CK Heatmap for the WayneCorp incident. The scoring scale in Appendix A1 ranges from contextual evidence through supported behaviour to core behaviour, allowing the most strongly evidenced attacker techniques to be distinguished visually from those that are only inferred. Both incidents reveal critical control gaps that enabled adversary progression from initial access to impact.

4.1 Attack Chain Reconstruction

Scenario A: Website Compromise (www.imreallynotbatman.com)

- Attacker (23.22.63.114) launched brute force against Joomla admin: 412 attempts in 60 seconds
- Following credential compromise, secondary infrastructure (40.80.148.42) uploaded 3791.exe
- **Kill chain:** Initial Access -> Credential Access -> Command and Control (Lockheed Martin, 2011; MITRE, 2024)

Scenario B: Ransomware Attack (Workstation we8105desk)

- Bob Smith opened Miranda_Tate_unveiled.dotm from USB drive found in parking lot
- Macro deployed VBScript (20429.vbs -> 121214.tmp) via multi-stage execution
- Lateral movement to file server 192.168.250.100, encrypting 257 PDFs remotely and 406 text files locally
- **Kill chain:** Execution -> Defense Evasion -> Lateral Movement -> Impact

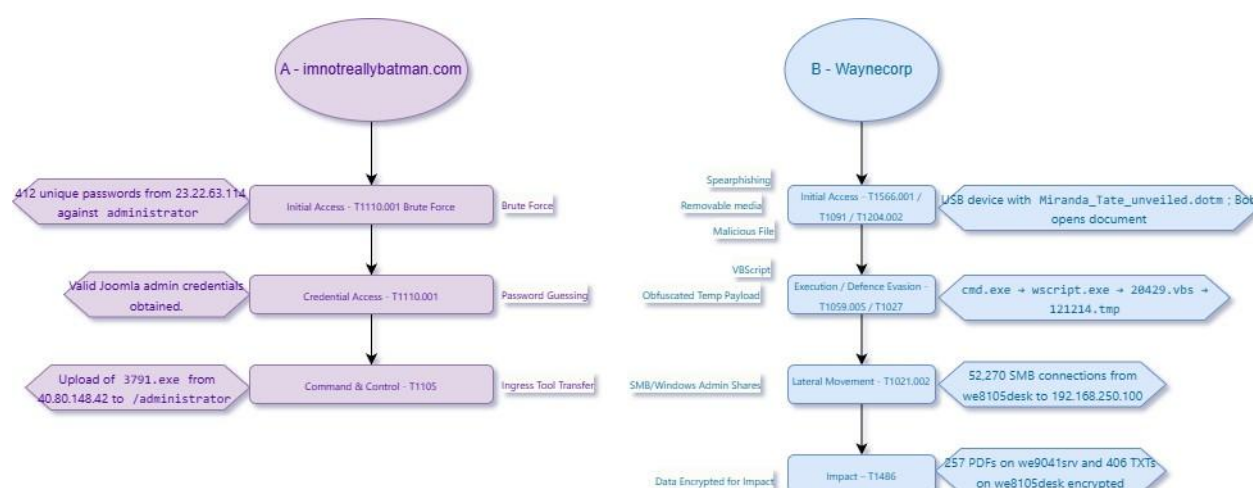


Figure 4.1.1 - High-level kill chain for Scenario A (Joomla compromise) and Scenario B (ransomware), showing mapped ATT&CK tactics, techniques and key observables.

4.2 MITRE ATT&CK Tactic Mapping

Each phase demonstrates how minor control gaps compounded into full operational impact.

4.2.1 Initial Access (TA0001)

T1566.001 - Phishing: Spearphishing Attachment

Bob Smith opened Miranda_Tate_unveiled.dotm from USB media. Filename exploited curiosity by referencing Wayne Enterprises' board member. Physical USB delivery bypassed email security controls entirely.

D3FEND Countermeasures:

- D3-EFA (Emulated File Analysis): Sandbox macro documents before user access

- D3-MACR (Mandatory Access Control): Block USB mounting for standard users via Group Policy
- D3-FA (File Analysis): Detect malicious VBA patterns

4.2.2 Execution (TA0002)

T1204.002 - User Execution / T1059.005 - VBScript

Macro deployed 20429.vbs to AppData\Roaming, initiating execution chain: cmd.exe (PID 3884) -> wscript.exe (PID 3968) -> 20429.vbs -> 121214.tmp (Section 2.7). The .tmp extension disguised payload. No elevated privileges were required; execution occurred entirely within Bob's user context. Payloads resided in AppData directories frequently exempted from real-time antivirus scanning.

D3FEND Countermeasures:

- D3-UDAC (User Data Access Control): Disable macro auto-execution via Office policies
- D3-PLA (Process Lineage Analysis): Flag wscript.exe spawning executables from user directories
- D3-EAI (Execution Isolation): Block unsigned binaries from AppData via application whitelisting

4.2.3 Defense Evasion (TA0005)

T1027 - Obfuscated Files or Information

Ransomware used .tmp extension with numeric naming (121214.tmp) to disguise executable nature.

D3FEND Countermeasures:

- D3-FA (File Analysis): Use magic byte analysis for file type identification, not extensions
- D3-FCAA (File Creation Analysis): Monitor executable creation in user-writable paths regardless of extension

4.2.4 Credential Access (TA0006)

T1110.001 - Brute Force: Password Guessing

External IP 23.22.63.114 performed 412 password attempts in 60 seconds on Joomla /administrator/. Dictionary words ("hotdog", "yellow", "camaro") indicate automated wordlist attack. No account lockout triggered.

D3FEND Countermeasures:

- D3-AETH (Authentication Event Thresholding): Rate-limit to 5 attempts per 15 minutes

- D3-SCF (Strong Credential Fabrication): Enforce complex passwords with MFA for admin interfaces

4.2.5 Lateral Movement (TA0008)

T1021.002 - Remote Services: SMB/Windows Admin Shares

Ransomware established 52,270 SMB connections from we8105desk to 192.168.250.100, massively exceeding baseline. Leveraged Bob's cached credentials (WAYNECORPINC\bob.smith). High frequency reflects encryption workflow.

D3FEND Countermeasures:

- D3-NTA (Network Traffic Analysis): Alert on anomalous SMB connection volume via baseline deviation
- D3-NI (Network Isolation): VLAN segmentation preventing direct workstation-to-server SMB access
- D3-DNSTA (Dynamic Network Traffic Analysis): Real-time detection of abnormal file access patterns

4.2.6 Command and Control (TA0011)

T1105 - Ingress Tool Transfer

External IP 40.80.148.42 uploaded 3791.exe via HTTP POST on August 10, 2016 at 21:52:47. Abused legitimate Joomla upload functionality, bypassing network-based executable transfer controls.

D3FEND Countermeasures:

- D3-NTA (Network Traffic Analysis): Flag executable uploads to web servers from external IPs
- D3-FA (File Analysis): Scan uploaded files for malware before write completion
- D3-APH (Application Hardening): Restrict file upload functionality to internal IPs only

4.2.7 Impact (TA0040)

T1486 - Data Encrypted for Impact

Ransomware encrypted 257 PDFs remotely and 406 text files locally. Workflow: enumerate -> read (READ_CONTROL) -> create encrypted copy (.cerber) -> delete original (DELETE). Windows Event ID 5145 captured 267 DELETE operations; Sysmon EventCode 2 showed 406 files modified in one second. Ransom notes (# DECRYPT MY FILES #.txt, .html, .url, .vbs) indicates ransomware (potential Cerber).

D3FEND Countermeasures:

- **D3-FCAA (File Creation Analysis):** Alert on mass file modification (>100 files per minute threshold)
- **D3-FAPA (File Access Pattern Analysis):** Detect sequential read-write-delete patterns across file types
- **D3-DF (Decoy File):** Deploy honeypot files triggering immediate isolation when encrypted
- **D3-BUP (File Backup):** Enable automated versioning for rapid restoration without ransom payment

4.3 Technique Summary Mapping

MITRE Tactic	Technique ID	Technique Name	Evidence	Severity	Detection Rule
TA0001 - Initial Access	T1566.001	Spearphishing Attachment	2.7	High	5
TA0002 - Execution	T1204.002	User Execution: Malicious File	2.7	High	5
TA0002 - Execution	T1059.005	Command/Scripting Interpreter: VBScript	2.7	High	5
TA0005 - Defense Evasion	T1027	Obfuscated Files/Information	2.7	Medium	5
TA0006 - Credential Access	T1110.001	Brute Force: Password Guessing	2.2, 2.3	High	2
TA0008 - Lateral Movement	T1021.002	Remote Services: SMB/Admin Shares	2.4	Critical	3
TA0011 - Command & Control	T1105	Ingress Tool Transfer	2.1	High	1
TA0040 - Impact	T1486	Data Encrypted for Impact	2.4, 2.5, 2.6	Critical	3, 4

The ATT&CK heatmap in Appendix A1 is derived from the techniques and severities listed in Table 1.3. Techniques highlighted in the darkest colour correspond to core behaviours with strong, direct log evidence and High or Critical severity (T1204.002, T1059.005, T1110.001, T1105 and T1486), all of which are mapped to at least one dedicated detection rule (Rules 1-

4). Mid-tone cells represent supporting behaviours such as T1027 and T1021.002, where the logs clearly indicate obfuscated payloads and high-volume SMB access but with slightly less direct evidence. The lightest cells reflect contextual initial-access techniques like T1566.001, which shape the infection story but are mainly addressed through preventive D3FEND controls (USB and macro policies) rather than standalone SIEM correlation rules.

4.4 MITRE D3FEND Defensive Architecture

Controls are grouped by their role in preventing, detecting, and containing adversary activity across the attack chain.

Harden (D3-H) - *Primary Prevention*

- **D3-APH (Application Hardening):** Restrict file uploads to specific file types and internal IP ranges only
- **D3-SCF (Strong Credential Fabrication):** Enforce 12+ character passwords with multi-factor authentication for admin interfaces
- **D3-MACR (Mandatory Access Control):** Block USB device mounting for standard users via Group Policy

Detect (D3-D) - *Visibility Layer*

- **D3-NTA (Network Traffic Analysis):** Baseline deviation detection for HTTP POST volume and SMB connection frequency
- **D3-FA (File Analysis):** Content-based malware scanning of uploads and macro-enabled documents
- **D3-PLA (Process Lineage Analysis):** Flag wscript.exe spawning executables from user-writable paths
- **D3-FCAA (File Creation Analysis):** Alert on mass file modification events
- **D3-LAM (Local Account Monitoring):** Track authentication failures with automated response thresholds

Isolate (D3-I) - *Containment*

- **D3-NI (Network Isolation):** VLAN segmentation preventing direct workstation-to-server SMB connectivity
- **D3-EAI (Execution Isolation):** Application whitelisting blocking unsigned executables from AppData directories

Evict (D3-E) - *Active Response*

- **D3-CRA (Credential Revoking):** Automate password reset and session termination upon brute force detection

- **D3-PTA (Process Termination):** EDR-based automated killing of malicious processes

4.5 Threat Actor Attribution

The TTPs indicate a financially motivated cybercriminal using commodity tooling. There is no evidence of custom malware, zero-day exploitation or tailored reconnaissance. The ransomware is Cerber, operating as Ransomware-as-a-Service, and the dual web-plus-USB vectors point to opportunistic targeting (Cisco Talos, 2016; Kaspersky Lab, 2016) that exploits user behaviour rather than a bespoke, targeted campaign.

4.6 Security Posture Gap Analysis

Gap	Enabled Technique	Remediation
No authentication controls on Joomla	T1110.001	5-attempt lockout, CAPTCHA after 3 failures, enforce MFA
Unrestricted macro execution	T1059.005	Deploy EDR with behavioral analytics; disable macros via Group Policy
No network segmentation	T1021.002	Implement zone-based firewall; require jump host for file server access
Unrestricted USB access	T1566.001	Disable USB storage for standard users via Group Policy
No file upload validation	T1105	Magic byte validation; integrate malware scanning; restrict to internal IPs

Most critical finding: Defense-in-depth was absent. A single compromised user cascaded into full file server encryption because no compensating controls existed at any layer.

5 References

MITRE (2024) *ATT&CK® for Enterprise*. Available at: <https://attack.mitre.org> (Accessed: 7 February 2026).

MITRE (2024) *MITRE D3FEND™*. Available at: <https://d3fend.mitre.org> (Accessed: 7 February 2026).

Lockheed Martin (2011) *Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains*. Lockheed Martin Corporation.

Available at: <https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Intel-Driven-Defense.pdf> (Accessed: 7 February 2026).

Cisco Talos (2016) Ransomware: Cerber rising. Cisco Talos Intelligence Group Blog.
Available at: <https://blog.talosintelligence.com> (Accessed: 7 February 2026).

Kaspersky Lab (2016) Cerber ransomware: how it works and how to protect yourself. Securelist.
Available at: <https://securelist.com> (Accessed: 7 February 2026).

Microsoft (2021) Macro malware, script-based attacks and hardening guidance. Microsoft Security Blogs.
Available at: <https://www.microsoft.com/security/blog> (Accessed: 7 February 2026).

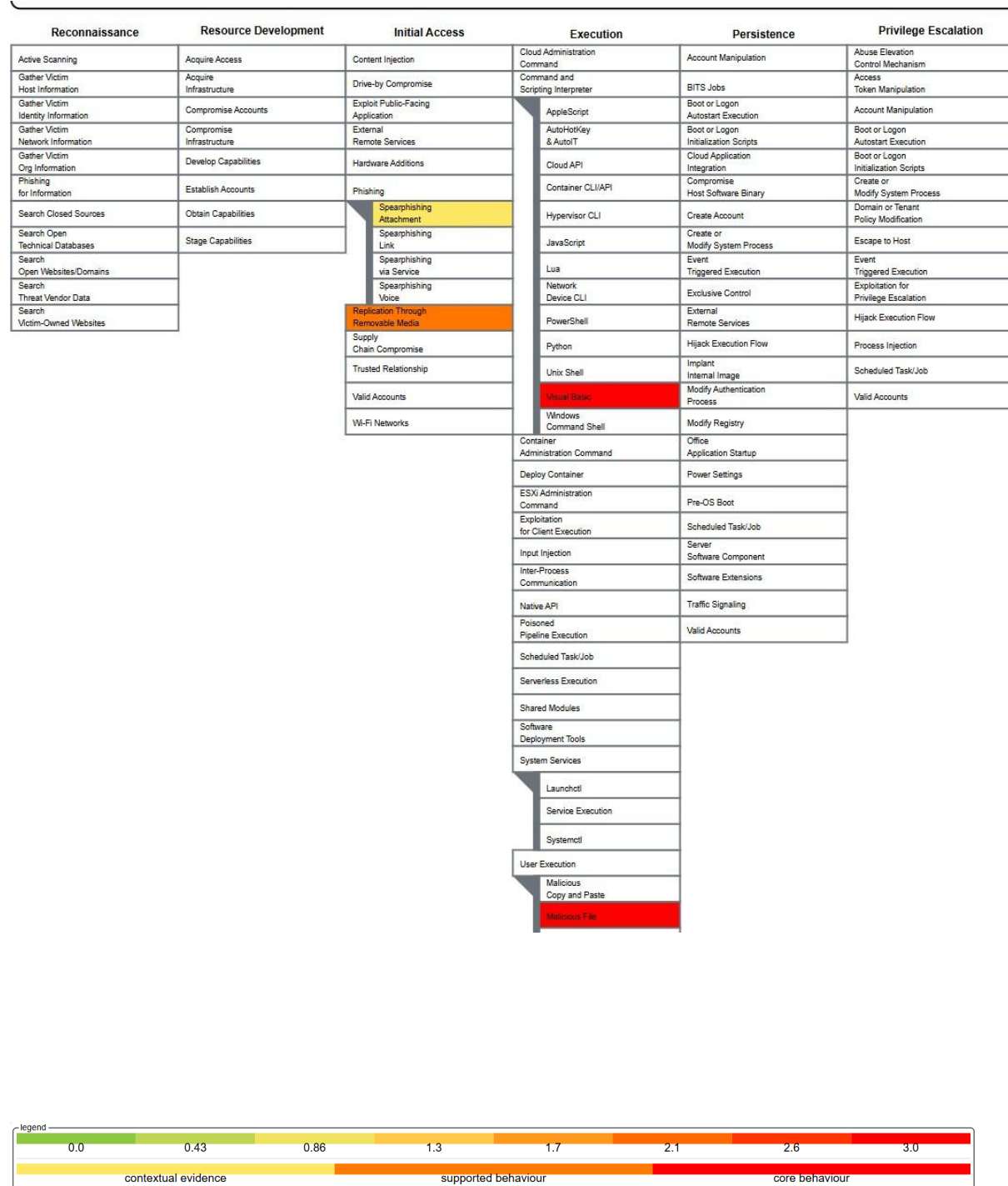
OWASP (2021) *OWASP Testing Guide v4: File Upload Testing*. OWASP Foundation.
Available at: <https://owasp.org> (Accessed: 7 February 2026).

Scaife, N., Carter, H., Traynor, P. and Butler, K.R.B. (2016) 'Cryptolock (and drop it): stopping ransomware attacks on user data', in *2016 IEEE 36th International Conference on Distributed Computing Systems (ICDCS)*. Piscataway, NJ: IEEE, pp. 303-312.

Kharraz, A., Robertson, W., Balzarotti, D., Bilge, L. and Kirda, E. (2015) 'Cutting the Gordian knot: A look under the hood of ransomware attacks', in *International Conference on Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA 2015)*. Cham: Springer, pp. 3-24.

6 Appendices

A1. MITRE ATT&CK Heatmap



Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Abuse Elevation Control Mechanism	Adversary-in-the-Middle	Account Discovery	Exploitation of Remote Services	Adversary-in-the-Middle	Application Layer Protocol	Automated Exfiltration	Account Access Removal
Access Token Manipulation	Brute Force	Application Application	Internal Spearphishing	Archive Collected Data	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
BITS Jobs	Credential Stuffing	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol	File Deletion
Build Image on Host	Password Cracking	Cloud Infrastructure Discovery	Remote Service Session Hijacking	Automated Collection	Data Encoding	Exfiltration Over C2 Channel	Data Manipulation
Debugger Evasion	Phishing	Cloud Service Dashboard	Remote Services	Browser Session Hijacking	Data Obfuscation	Exfiltration Over Other Network Medium	Defacement
Delay Execution	Password Spraying	Cloud Service Discovery	Cloud Services	Clipboard Data	Dynamic Resolution	Exfiltration Over Physical Medium	Disk Wipe
Deobfuscate/Decode Files or Information	Credentials from Password States	Cloud Storage	Direct Cloud VM Connections	Data from Cloud Storage	Encrypted Channel	Exfiltration Over Web Service	Email Bombing
Deploy Container	Exploitation for Credential Access	Container and Resource Discovery	Distributed Component Object Model	Data from Configuration Repository	Fallback Channels	Scheduled Transfer	Endpoint Denial of Service
Direct Volume Access	Forced Authentication	Debugger Evasion	Remote Desktop Protocol	Data from Information Repositories	Hide Infrastructure	Transfer Data to Cloud Account	Financial Theft
Domain or Tenant Policy Modification	Forge Web Credentials	Device Driver Discovery	SMB/Windows Admin Shares	Data from Local System	Session hijacking		Firmware Corruption
Email Spoofing	Input Capture	Domain Trust Discovery	SSH	Data from Network Shared Drive	Multi-Stage Channels		Initial System Recovery
Execution Guardrails	Modify Authentication Process	File and Directory Discovery	VNC	Data from Removable Media	Non-Application Layer Protocol		Network Denial of Service
Exploitation for Defense Evasion	Multi-Factor Authentication Interception	Group Policy Discovery	Windows Remote Management	Data Staged	Non-Standard Port		Resource Hijacking
File and Directory Permissions Modification	Multi-Factor Authentication Request Generation	Local Storage Discovery	Replication Through Removable Media	Email Collection	Protocol Tunneling		Service Stop
Hide Artifacts	Network Sniffing	Log Enumeration	Software Deployment Tools	Input Capture	Proxy		System Shutdown/Reboot
Hijack Execution Flow	OS Credential Dumping	Network Service Discovery	Taint Shared Content	Screen Capture	Remote Access Tools		
Impair Defenses	Steal Application Access Token	Network Share Discovery	Use Alternate Authentication Material	Video Capture	Traffic Signaling		
Impersonation	Steal or Forge Authentication Certificates	Network Sniffing			Web Service		
Indicator Removal	Steal or Forge Remote Tickets	Password Policy Discovery					
Indirect Command Execution	Steal Web Session Cookies	Peripheral Device Discovery					
Masquerading	Unsecured Credentials	Permission Groups Discovery					
Modify Authentication Process		Process Discovery					
Modify Cloud Compute Infrastructure		Query Registry					
Modify Cloud Resource Hierarchy		Remote System Discovery					

Fig A1.1 - ATT&CK heatmap for the Gotham/WayneCorp incident, combining the web-server compromise of *imreallynotbatman.com* and the ransomware attack on workstation *we8105desk* and file server *we9041srv*.

Figure A1.1 encodes technique usage and evidential strength on a 0-3 scale aligned with the evidence table. Techniques scored 3 (core behaviour) have strong, direct log evidence, such as T1204.002 (user execution of *Miranda_Tate_unveiled.dotm*), T1059.005 (VBScript execution of *20429.vbs*), T1110.001 (412 brute-force passwords), T1105 (upload of *3791.exe*) and T1486 (257 PDFs and 406 TXTs encrypted). Techniques scored 2 (supported behaviour), including T1091, T1027 and T1021.002, have clear but slightly less direct support. For example, numeric .tmp payload obfuscation and high-volume SMB connections. Techniques scored 1 (contextual behaviour), such as T1566.001, are inferred from the case narrative and artefacts (malicious .dotm on USB) but are not directly captured in telemetry.

A2. Windows and Sysmon Event IDs

Category	Event ID(s)
Account logon / logoff activity	4624, 4625, 4634, 4647
Windows Firewall / network connection logs	2004, 2005, 2006, 2009, 2033
Object access - file share (SMB)	5140, 5145
Log clearing	1102
Windows Update / patch installation	2, 19
Group Policy / configuration changes	1125, 1127, 1129

Table A.2.1 - System event IDs

Category	Event ID
Sysmon service status changed	0
Process Create	1
File Creation Time Changed	2

Network Connection	3
Process Terminated	5
Driver Loaded	6
Image Loaded	7

Table A.2.2 - Sysmon event IDs